The Phishermen's Intrusion Report #2

Table of Contents

Table of Contents **0**
Overview **2**
Wazuh 2
Mitigating Measures **2**
Active Directory 2
Ticketing Machine 3
Management Backend 3
Admin User Interface 4
Website 4

Attacks **5**
Structured Query Language injection (SQLi) & Lightweight Directory Access Protocol injection (LDAPi) 5
Account Takeover 6
Conclusion **7**

Overview

Wazuh

We deployed and utilized Wazuh to track all traffic on our networks, and to analyze attacks in greater detail.

Throughout the competition, the Red Team executed attacks that triggered our Wazuh agents. The details of the observed attacks are documented below.

Mitigating Measures

A combined use of a penetration test and analysis of machine settings and codebases identified a myriad of weaknesses in the network.

Active Directory

1. Re-configured incorrectly-configured groups
    a. Removed the `Domain Users` group from the `Domain Admins` group
    b. Removed the `Transit Admins` group from the `Domain Admins` group
    c. Restricted Remote Desktop Protocol (RDP) access to only `IT Administrators`, per the provided Scenario

2. EternalBlue Prevention
    a. Disabled `SMBv1`

Ticketing Machine

1. Removed Malware
    a. Removed `sus.exe` executable from startup, and deleted the executable
2. Audited Users
    a. Removed `backdoor` and `scrat` malicious users
3. Hardened Codebase
    a. Migrated HTTP to HTTPS
    b. Added authentication checks to select endpoints

Management Backend

1. Re-configured allowed elevated permissions
    a. Modified `/etc/sudoers` file to only allow for `IT Administrators` to run commands with elevated permissions
2. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Disabled Authentication Bypass to Administrator
    c. Disabled Remote Code Execution via Debug Mode

Admin User Interface

1. Removed malware
    a. Deleted malicious `notpad_original.exe` and `backdoor.bat` files
2. Audited Users
    a. Removed `scrat` and `taco` users
3. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Disabled Remote Code Execution via Debug Mode

Website

1. Removed Malicious LD_PRELOAD nsabackdoor.so
2. Removed three (3) listening ports running netcat (nc), which would allow for an immediate root reverse shell
3. Removed two services in systemd which allow for immediate privileged access
4. Revised /etc/sudoers file to only allow for IT Administrators and root to run commands with elevated permissions
5. Hardened Codebase
    a. Updated SECRET_KEY to use a secure, 32-byte hex string
    b. Migrated from HTTP to HTTPS

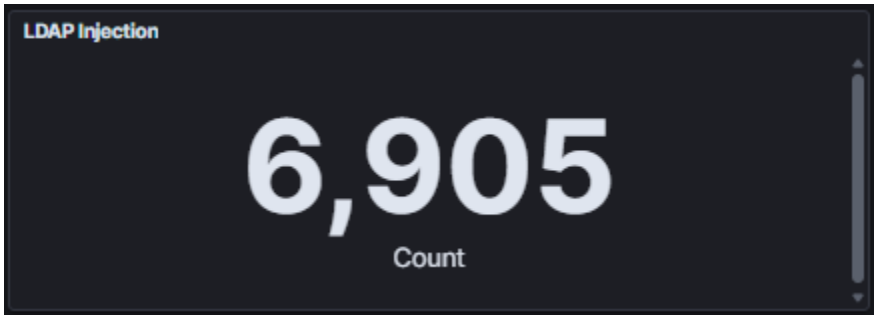
Attacks

Our IDS (Wazuh) detected numerous attacks from `09:30 am CST` to `12:30 pm CST` on `2026-02-21`.

Structured Query Language injection (SQLi) & Lightweight Directory Access Protocol injection (LDAPi)

At approximately `10:12am CST` on `2026-02-21`, Red Team attempted to compromise our websites via SQLi and LDAPi through the use of a tool called SQLMap. To mitigate this attack, we restricted the adversary's ability to access our endpoints via IP blocking. We plan to implement rate limiting to prevent similar attacks from resulting in

The first indicator of compromise occurred when our Wazuh dashboard displayed an overwhelming number of LDAP Injection incidents



Further analysis showed Red Team was utilizing SQLMap (as was shown by the request headers and scan behavior


```
er_agent": "sqlmap/1.10.2.16#dev (https://sqlmap.org)", "referer": "http://www.team1.isucdc.com/login`) WHERE 9775=9775 A
ND 1502=1502-- NSCW", "origin": "", "content_type": "application/x-www-form-urlencoded; charset=utf-8", "content_length":
 27, "session": {"username": null}, "url_params": {}}
{"timestamp": "2026-02-21T10:12:34", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "5d71215
d", "event_type": "frontend_http_request", "endpoint": "login", "http_method": "POST", "url_path": "/login", "query_param
s": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 401, "response_time_ms": 110.61, "u
ser_agent": "sqlmap/1.10.2.16#dev (https://sqlmap.org)", "referer": "http://www.team1.isucdc.com/login`=`http://www.team1
.isucdc.com/login` AND 5579=9786 AND `http://www.team1.isucdc.com/login`=`http://www.team1.isucdc.com/login", "origin": "
", "content_type": "application/x-www-form-urlencoded; charset=utf-8", "content_length": 27, "session": {"username": null
}, "url_params": {}}
{"timestamp": "2026-02-21T10:12:34", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "ab2e8c9
b", "event_type": "frontend_http_request", "endpoint": "login", "http_method": "POST", "url_path": "/login", "query_param
s": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 401, "response_time_ms": 72.2, "use
r_agent": "sqlmap/1.10.2.16#dev (https://sqlmap.org)", "referer": "http://www.team1.isucdc.com/login`=`http://www.team1.i
sucdc.com/login` AND 1502=1502 AND `http://www.team1.isucdc.com/login`=`http://www.team1.isucdc.com/login", "origin": "",
 "content_type": "application/x-www-form-urlencoded; charset=utf-8", "content_length": 27, "session": {"username": null},
 "url_params": {}}
{"timestamp": "2026-02-21T10:12:34", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "5e4c3cf
1", "event_type": "frontend_http_request", "endpoint": "login", "http_method": "POST", "url_path": "/login", "query_param
s": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 401, "response_time_ms": 88.56, "us
er_agent": "sqlmap/1.10.2.16#dev (https://sqlmap.org)", "referer": "http://www.team1.isucdc.com/login\"=\"http://www.team
1.isucdc.com/login\" AND 1339=6548 AND \"http://www.team1.isucdc.com/login\"=\"http://www.team1.isucdc.com/login", "origi
n": "", "content_type": "application/x-www-form-urlencoded; charset=utf-8", "content_length": 27, "session": {"username":
 null}, "url_params": {}}
{"timestamp": "2026-02-21T10:12:34", "level": "INFO", "logger": "root", "message": "http_request", "request_id": "c614c10
1", "event_type": "frontend_http_request", "endpoint": "login", "http_method": "POST", "url_path": "/login", "query_param
s": {}, "src_ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com", "response_status": 401, "response_time_ms": 83.37, "us
er_agent": "sqlmap/1.10.2.16#dev (https://sqlmap.org)", "referer": "http://www.team1.isucdc.com/login\"=\"http://www.team
1.isucdc.com/login\" AND 1502=1502 AND \"http://www.team1.isucdc.com/login\"=\"http://www.team1.isucdc.com/login", "origi
n": "", "content_type": "application/x-www-form-urlencoded; charset=utf-8", "content_length": 27, "session": {"username":
 null}, "url_params": {}}
```


Per our logging, this attempt to gain access to our network had **no impact** on our operations.

Account Takeover

Red Team attempted to register a user called blue_flag in hopes of exploiting a discrepancy between the Active Directory Users and the MariaDB users.

The first attempted compromise occurred at `12:13pm CST` on `2026-02-21`


```
ip": "127.0.0.1", "dst_host": "www.team1.isucdc.com"
Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:147
c.com/register", "origin": "http://www.team1.isucdc.
ength": 42, "session": {"username": "blue_flag"}, "u
```

Red Team attempted this same exploit numerous times, including instances of credit card number access attempts. Due to our prior creation and disabling of the `blue_flag` user, these exploits were unsuccessful.

Conclusion

Actions were taken to compromise our network; however, no attacks taken were successful. As such, our network remains stable and secure.